Pashov Audit Group

DefiApp
Security Review

May 23rd 2026 - May 25th 2026

Contents

1. About Pashov Audit Group

Pashov Audit Group consists of 40+ freelance security researchers, who are well proven in the space - most have earned over $100k in public contest rewards, are multi-time champions or have truly excelled in audits with us. We only work with proven and motivated talent.

With over 300 security audits completed — uncovering and helping patch thousands of vulnerabilities — the group strives to create the absolute very best audit journey possible. While 100% security is never possible to guarantee, we do guarantee you our team's best efforts for your project.

Check out our previous work here or reach out on Twitter @pashovkrum.

2. Disclaimer

A smart contract security review can never verify the complete absence of vulnerabilities. This is a time, resource and expertise bound effort where we try to find as many vulnerabilities as possible. We can not guarantee 100% security after the review or even if the review will find any problems with your smart contracts. Subsequent security reviews, bug bounty programs and on-chain monitoring are strongly recommended.

3. Risk Classification

Severity	Impact: High	Impact: Medium	Impact: Low
Likelihood: High	Critical	High	Medium
Likelihood: Medium	High	Medium	Low
Likelihood: Low	Medium	Low	Low

Impact

- **High** - leads to a significant material loss of assets in the protocol or significantly harms a group of users
- **Medium** - leads to a moderate material loss of assets in the protocol or moderately harms a group of users
- **Low** - leads to a minor material loss of assets in the protocol or harms a small group of users

Likelihood

- **High** - attack path is possible with reasonable assumptions that mimic on-chain conditions, and the cost of the attack is relatively low compared to the amount of funds that can be stolen or lost
- **Medium** - only a conditionally incentivized attack vector, but still relatively likely
- **Low** - has too many or too unlikely assumptions or requires a significant stake by the attacker with little or no incentive

4. Methodology

Pashov Audit Group conducts each engagement as a team that works through the codebase end-to-end: we map the system, hunt for bugs, and then collaborate with the client to remediate the findings. This report tracks every commit reviewed, every finding raised, and the resolution status of each issue. Our auditors draw on experience from private engagements and public contests, and pick their own toolset per project — static analysis, fuzzers, formal verification, and AI-assisted review — based on what fits the codebase.

5. About Defi App

DefiApp is a DeFi platform whose native HOME token is deployed as a LayerZero OFT (Omnichain Fungible Token) across Base, BNB Chain, and Solana. The token uses the standard LayerZero OFT implementation without source modifications.

The HOME token is a LayerZero OFT (Omnichain Fungible Token) deployed on three chains:

- **Base**: `0x4bfaa776991e85e5f8b1255461cbbd216cfc714f`
- **BNB Chain**: `0x4bfaa776991e85e5f8b1255461cbbd216cfc714f`
- **Solana**: `J3umBWqhSjd13sag1E1aUojViWvPYA5dFNyqpKuX3WXj`

The deployed contracts are the **standard LayerZero OFT implementation with no custom modifications to the contract source code**. On Base the token is `HomeCanonical` (inheriting `MintableOFT` → `BaseOFT`), on BNB Chain it is `Home` (inheriting `BaseOFT`), and on Solana it is the standard LayerZero OFT Anchor program. The project's `defi-app-oft` repository contains only the deployment scripts, LayerZero wiring configuration, and the Solana bridge setup that produced the on-chain state being reviewed.

The scope of this review is the live on-chain deployment of the three HOME OFT contracts together with their full configuration. It included the ownership and delegate configuration of each OFT contract (Gnosis Safe on EVM chains and Squads V4 on Solana), the LayerZero peer wiring across all three chains, the DVN (Decentralized Verifier Network) setup, send/receive library configuration, executor configuration, enforced options, rate limits, and confirmation thresholds. Each parameter was verified directly on-chain on Base, BNB Chain, and Solana, and cross-referenced against the configuration files in the `defi-app-oft` repository.

The goal of the review was to ensure that the HOME OFT token's cross-chain messaging path between Base, BNB Chain, and Solana cannot be abused to mint or forge tokens, and that privileged roles and quorum thresholds are configured consistently and defensively across all three chains.

6. Executive Summary

A time-boxed security review of the **defi-app/defi-app-oft** repository was done by Pashov Audit Group, during which **Tejas Warambhe, 0x37, unforgiven** engaged to review **Defi App**. A total of **3** issues were uncovered.

Protocol Summary	
Project Name	Defi App
Protocol Type	Cross-chain OFT token
Timeline	May 23rd 2026 - May 25th 2026

Review commit hash:

- 85068b8fd68d974928b249383a2931045a34b486 (defi-app/defi-app-oft)

Scope

`Home.sol` `HomeCanonical.sol` `BaseOFT.sol` `MintableOFT.sol` `lib.rs (Solana OFT program)` `layerzero.config.ts`

7. Findings

Findings count

Severity	Amount
Low	3
Total findings	**3**

Summary of findings

ID	Title	Severity	Status
[L-01]	Layerzero config file includes 1-of-1 DVN setup	Low	Acknowledged
[L-02]	No rate limits configured on any peer	Low	Acknowledged
[L-03]	Inconsistent multisig threshold between EVM chain and Solana chain	Low	Acknowledged

Low findings

[L-01] Layerzero config file includes 1-of-1 DVN setup

Even so the on-chain data shows the 3-of-3 DVN setups for OFT token (Canary, LayerZero Labs, Deutsche Telekom), project's Layerzero config file `layerzero.config.ts` still uses 1-of-1 setup which is vulnerable:

```
    [
        baseContract, // Chain B contract
        bnbContract, // Chain C contract
        [['LayerZero Labs'], []], // [ requiredDVN[], [ optionalDVN[], threshold ] ]
        [6, 12], // [A to B confirmations, B to A confirmations]
        [EVM_ENFORCED_OPTIONS, EVM_ENFORCED_OPTIONS], // Chain C enforcedOptions, Chain B
enforcedOptions
    ],
```

It's recommended to update the config file to reflect the current on-chain setup.

[L-02] No rate limits configured on any peer

The current codebase contains files such as `setInboundRateLimit.ts` and `setOutboundRateLimit.ts` which would help in setting up the inbound / outbound rate limits on peers.

However, upon on-chain inspection, it was found that the current deployment does not contain any rate limits.

A single `lzReceive` authorized by the 3-DVN quorum can mint up to the entire 10B circulating supply on any one of the three chains in one transaction.

It is recommended to set up rate limits in case they were missed unintentionally.

[L-03] Inconsistent multisig threshold between EVM chain and Solana chain

In Home OFT, the owner and the delegate address is controlled by one multisig address, Genosis safe in EVM and Squads V4 in Solana.

The setting for these two multisig addresses is a little different.

In https://basescan.org/address/0x2D46c05F59E6E17D445f124c686Bc478267D3261#readProxyContract, the number of owners is 7. The threshold is 4/7. In https://solscan.io/account/3j2cPSRvAgiJyKw5F65xrLe2DznujKxrRqr4evXrK7QD#programMultisig, the number of owners is 8. The threshold is 5/8.

In some special cases, the protocol team may want to update config for all configured chains. When there are only 4 available voters, some chains can be allowed to be configured, and another chain is not allowed to be configured.

It's suggested to share the same multisig configuration. Then they can update configs for different chains at the same time.